

Actividad 01- Análisis y planificación de pentest

Yareli Yubiditzi Villagrana Mora

Hacker Women Council- Ethical Hacking

1. Objetivos

- Establecer vulnerabilidades y riesgos a los que está expuesto Aurora Market.
- Conocer que podría descubrir un atacante.
- Establecer medidas de seguridad para reducir los ataques.

2. Alcance

Si se evaluara:

- Aplicación web.
- Base de datos.
- Mecanismos de autenticación.
- Tipos de usuario.

Fuera del alcance:

- No hay información técnica de la infraestructura.
- No se conoce que tecnologías se utilizan.

3. Autorización y condiciones

- Autorización a solo evaluar la aplicación web.
- No se permite atacar las redes sociales de la empresa, equipos personales de los empleados, cuentas de correos, proveedores externos.
- Realizar pruebas solo en horarios de menor actividad.
- No interrumpir el funcionamiento de la plataforma.

4. Tipo de pentest

El tipo de pentest es Black Box, ya que no se nos proporcionó la información de la infraestructura y no se nos otorgó permisos completos.

5. Planificación

Objetivos

Identificar vulnerabilidades dentro de la aplicación que puedan comprometer los datos de los clientes y mitigar los riesgos al proponer medidas de seguridad.

Alcance

Aplicación web, base de datos, mecanismos de autenticación, tipos de usuario.

Permisos y condiciones

Realizar pruebas solo en horarios de menor actividad, evaluar solo la aplicación web, no atacar redes sociales de la empresa, equipos personales de los empleados, cuentas de correos, proveedores externos y no interrumpir el funcionamiento de la aplicación.

Metodología a utilizar

La metodología a utilizar es la OWASP ya que está enfocada en las aplicaciones web, identificar problemas de seguridad mas comunes y como evitarlos y reducirlos y, para este escenario, es el más adecuado de aplicar.

Recopilación de información previa

Solo sabemos que un cliente informo que podría existir una violación de los datos personales de los clientes ya que se percato que los datos que aparecieron no eran los correctos y no coincidían con el usuario.

Recursos necesarios

- Computadora
- Acceso a internet
- Acceso a la aplicación web

Programación del pentest

Se planea ejecutar las pruebas por la noche que es cuando menor fluctuación de usuarios se observa en la página web.

6. Fases del pentest

Reconocimiento

Generar e identificar los objetivos.

Análisis de vulnerabilidades

Identificar cuáles son las debilidades que se presentan en la aplicación web y con la administración de los datos personales de los clientes.

Explotación

Analizar cuál es el impacto que tiene explotar la vulnerabilidad que hayamos encontrado y verificar que realmente sea una vulnerabilidad que sea preocupante.

Post explotación

Verificar cual es el alcance que tiene la vulnerabilidad que hemos encontrado y hasta donde podría escalar el problema al no contenerlo.

Informe

Una vez analizado todo el panorama, probado la aplicación y detectado aquellas vulnerabilidades que presentan una amenaza real para la empresa, se redactará un informe detallando los problemas que hemos identificado, cuándo es que se presentan y cual es la manera mas optima de reducir los riesgos y evitar las amenazas encontradas en el sistema. Siempre mostrando evidencias reales de las vulnerabilidades que hemos encontrado.

7. Investigación

La metrología OWASP me parece la mas adecuada para este escenario, ya que de las que vimos en clase, esta es la que mas se enfoca en las aplicaciones web y se centra en identificar problemas de seguridad mas comunes y como evitar y reducir aquellos problemas encontrados.

La manera en la que está detallado el top 10 me parece una herramienta muy útil, ya que detalla los diez riegos de seguridad mas comunes dentro de las aplicaciones web y analizando estos puntos y con lo que comunicó el cliente que encontró uno de los problemas, me parecería que sería un fallo en la autenticación y un fallo criptográfico, ya que según este reporte, había una filtración de datos personales.